DECISION DE ARQUITECTURA TECNOLOGICA

Consecutivo	289

Tipo	Solución	**Fecha aprobación**	2/03/2025
Titulo	Plataforma de gestión de riesgos operativos BPOP	**Estado**	Aceptado

Contexto

Actualmente, el Banco cuenta con el aplicativo Riskment Suite, correspondiente a la suite del proveedor PIRANI, orientada a la gestión integral de riesgos y cumplimiento. Esta solución ha sido utilizada como plataforma para soportar procesos asociados a la administración del riesgo operativo, permitiendo centralizar en un único entorno actividades como el registro, evaluación, seguimiento y control de eventos, riesgos y planes de acción.

No obstante, el equipo funcional de Riesgos ha identificado limitaciones relevantes en la flexibilidad funcional y metodológica de Riskment Suite, particularmente para ajustarse de manera adecuada a la metodología, lineamientos internos y necesidades específicas definidas por el Banco en materia de riesgo operativo. Esta situación ha generado la necesidad de evaluar alternativas que permitan una mayor alineación con el modelo de gestión requerido por la organización.

En ese contexto, el equipo de Analítica de Riesgos desarrolló EMMA (Evaluación Matricial y Monitoreo de Alertas), concebida inicialmente como una herramienta orientada a automatizar tareas propias del área de riesgo operativo, con un alcance principalmente enfocado en eficiencia operativa y soporte especializado al proceso. Bajo esta óptica inicial, la solución fue atendía por el Area de Arquitectura con el caso **"EMMA CASO 211"** presentado en varias iteraciones ante el Consejo de Arquitectura (ver anexo Actas Consejo Arquitectura) sin embargo, en dichas revisiones no fue aprobado, principalmente por debilidades identificadas en materia de controles de seguridad, así como por brechas en atributos arquitectónicos esperados para una solución con potencial de crecimiento institucional.

Posteriormente, en el mes de diciembre, el área de negocio indicó un cambio sustancial en la expectativa sobre EMMA, planteando que la herramienta no se limitaría a cumplir un rol de apoyo o automatización puntual, sino que reemplazaría a Riskment Suite y pasaría a constituirse en la plataforma oficial para la gestión del riesgo operativo del Banco. Esta definición modifica de forma importante la naturaleza de la solución, dado que EMMA deja de ser una herramienta táctica o de apoyo y pasa a ser considerada una aplicación de carácter misional, con impacto directo en procesos

críticos del Banco y con necesidad de responder a exigencias de disponibilidad, seguridad, trazabilidad, auditoría, escalabilidad, soporte, mantenibilidad y cumplimiento regulatorio.
En consecuencia, el cambio de alcance implica que la arquitectura inicialmente presentada para EMMA ya no resulta suficiente para atender el nuevo alcance. De acuerdo con lo anterior se realiza una revisión integral de la arquitectura, incorporando ajustes sustanciales que permitan robustecer la plataforma y llevarla a un nivel acorde con una aplicación misional del Banco. Bajo este nuevo escenario, es necesario definir formalmente cuál será la plataforma oficial para la gestión del riesgo operativo, evaluando no solo la alineación funcional y metodológica, sino también la viabilidad arquitectónica, tecnológica, operativa y de seguridad de la alternativa que se adopte como objetivo

Alternativas Evaluadas

Alternativa 1: Continuar con Riskment Suite del proveedor Pirani
Esta alternativa consiste en mantener Riskment Suite como la plataforma oficial para la gestión del riesgo operativo del Banco, apalancando la solución existente del proveedor y realizando, en la medida de lo posible, ajustes de parametrización, configuración o evolución sobre la herramienta actual.
Ventajas

- Solución ya implantada y conocida por el Banco.
- Cuenta con respaldo y soporte de un proveedor especializado.
- Reduce el esfuerzo de transición frente a una sustitución completa.
- Mantiene un esquema de operación soportado en una suite de mercado.

Desventajas

- No cumple con el alcance funcional derivado de la metodología de riesgo operativo adoptado con el banco, de conformidad con la información reportada por la vicepresidencia de riesgo
- Limitada flexibilidad para adaptarse a la metodología actual del Banco.
- Duplicidad de riesgos y controles derivada de la estructura de registro.
- Funcionalidades clave (planes de acción, KPI/KRI y reportería) no han podido ser utilizadas de manera efectiva.
- Alta manualidad en planes de acción, gestión de procesos y seguimiento de eventos.
- Dependencia de Excel, correos electrónicos y macros para trazabilidad y control de cambios.
- Construcción manual de mapas de calor por área o proceso.
- Debilidades en la calidad de los datos del reporte de eventos, con impactos en auditoría.
- Reportería no alineada a los requerimientos de Grupo Aval y áreas internas, generando reprocesos significativos (hasta una semana mensual de un recurso del equipo).
- No aprovechamiento efectivo de KPI y KRI ni posibilidad de relacionar adecuadamente componentes clave del control (ejecutores, herramientas TI, cuentas contables, entre otros).
- Limitaciones de trazabilidad y auditoría que han derivado en hallazgos y reprocesos.
- Dependencia del proveedor para ajustes que históricamente no han logrado resolver completamente la necesidad del Banco.

- Riesgo de continuar con una plataforma que no se ajusta plenamente al modelo objetivo de gestión.

Riesgos

- Persistencia de ineficiencias operativas y reprocesos.
- Continuidad de hallazgos o debilidades en auditoría.
- Dificultad para responder oportunamente a nuevas exigencias regulatorias o metodológicas.
- Mayor dependencia del proveedor sin garantía de adaptación efectiva.

Alternativa 2: Implementar EMMA

Esta alternativa consiste en adoptar EMMA como la plataforma oficial para la gestión del riesgo operativo del Banco, reemplazando a Riskment Suite y robusteciendo la solución para llevarla desde su concepción inicial como herramienta táctica hacia una aplicación misional.

Ventajas

- Solución diseñada a la medida de la metodología y lineamientos del Banco.
- Mayor flexibilidad funcional para adaptarse a cambios del negocio y regulatorios.
- Mejor capacidad para soportar la gestión de riesgos, eventos y planes de acción de acuerdo con la necesidad real del área.
- Posibilidad de autogestión por parte de usuarios en procesos que hoy son manuales.
- Potencial de mejorar reportería, trazabilidad y alineación metodológica.
- Reduce dependencia funcional de un proveedor externo para la evolución del modelo.

Desventajas

- La arquitectura inicialmente presentada no fue aprobada por debilidades en seguridad y controles.
- Requiere rediseño y fortalecimiento sustancial de la arquitectura para operar como solución misional.
- Implica asumir responsabilidades internas de construcción, soporte, mantenimiento y evolución.
- Requiere una ruta formal de industrialización, estabilización, gobierno y operación.
- Puede demandar inversiones adicionales en componentes técnicos, seguridad, observabilidad, continuidad y soporte.

Riesgos

- Que la solución sea promovida a rol misional sin cerrar previamente las brechas arquitectónicas y de seguridad.
- Riesgo de sostenibilidad si no se formaliza un modelo robusto de soporte, operación y evolución.
- Incremento de complejidad interna si no se definen claramente responsables, capacidades técnicas y esquema de mantenimiento.

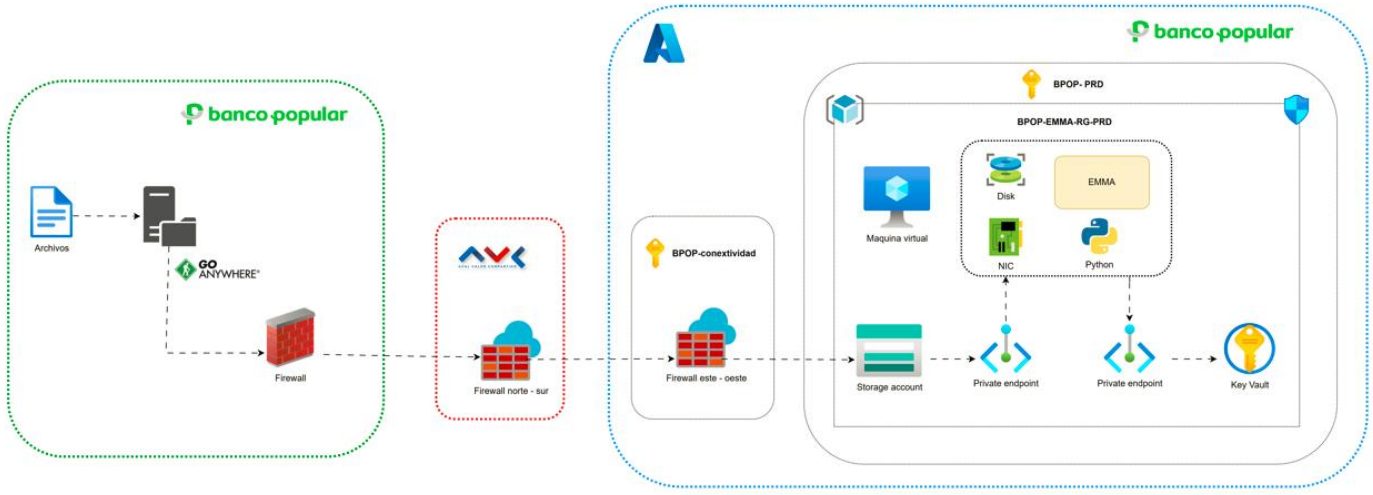
- Riesgo de incumplimiento regulatorio o de auditoría si la solución entra en producción sin los controles requeridos.

Decisión

Se define EMMA como la plataforma oficial (target) para la gestión del riesgo operativo del Banco, reemplazando progresivamente a Riskment Suite (Pirani).
Esta decisión se sustenta en que EMMA fue desarrollada a la medida y permite una alineación integral con la metodología y lineamientos del Banco, además de habilitar capacidades que hoy no se logran operar adecuadamente con Riskment Suite (p. ej., planes de acción, reportería, trazabilidad y autogestión), reduciendo manualidades y reprocesos.

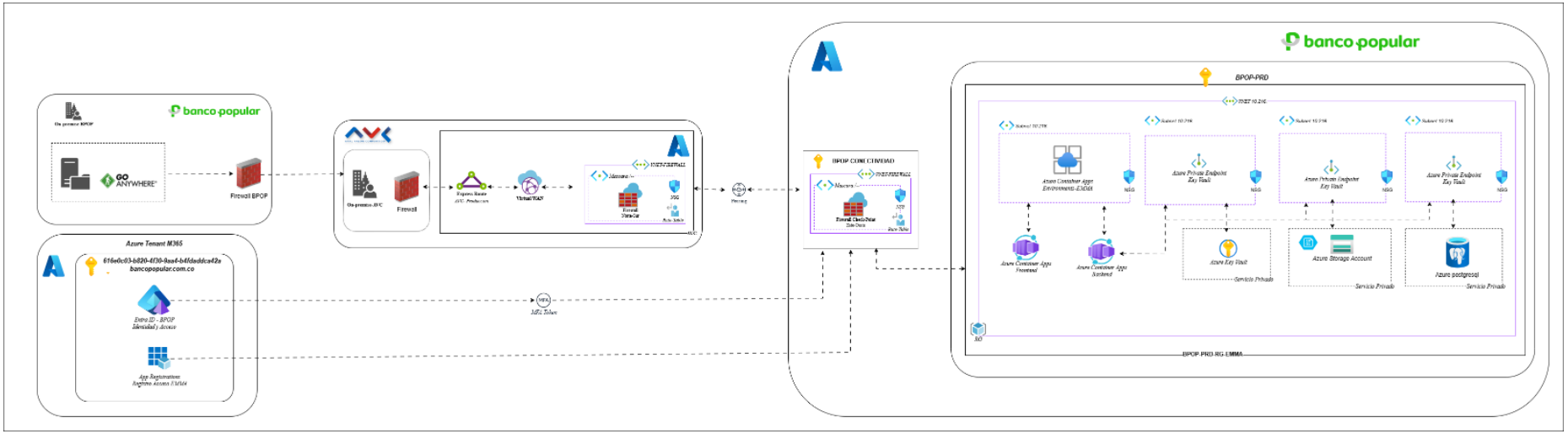
Dado que EMMA fue concebida inicialmente como herramienta de automatización táctica y en iteraciones anteriores no fue aprobada por debilidades en seguridad y controles, la adopción como aplicación misional se aprueba condicionada a ejecutar un cambio sustancial de arquitectura, cerrando brechas de seguridad, auditoría, trazabilidad, disponibilidad, soporte y operación, conforme a los estándares corporativos. La puesta en producción y/o ampliación de alcance quedará sujeta al cumplimiento de estos habilitadores y a la validación por el Consejo de Arquitectura.

Propuesta de arquitectura de automatización



Esta versión no fue aprobada en el Consejo de Arquitectura CASO EMMA 211

Arquitectura para habilitación de EMMA como aplicación misional



Recomendaciones

- Integrar autenticación obligatoria con Entra ID / IDM y eliminar accesos locales.
- Implementar control de acceso basado en roles (RBAC) y gestión formal del ciclo de vida de usuarios.
- Habilitar logs de auditoría completos.
- Migrar de archivos planos a una base de datos empresarial con cifrado, auditoría e integridad referencial.
- Cumplir protocolo de migración de datos.
- Formalizar un SDLC seguro con SAST, SCA, DAST y modelado de amenazas.
- Definir gobierno TI del aplicativo (RACI, control de cambios, modelo operativo).
- Clasificar la información y aplicar cifrado y enmascaramiento según criticidad.
- Implementar monitoreo y trazabilidad alineados a estándares corporativos.
- Establecer un plan de transición de Riskment Suite a Emma que garantice continuidad operativa
- Se deben realizar respaldos automáticos y periódicos de la información, garantizando su recuperación oportuna y alineándose con las políticas de respaldo y retenciones definidas por el Banco

Requerimientos no funcionales

Característica	Aplica / No aplica (Justificación)
Disponibilidad	La aplicación debe estar disponible de manera continua para soportar los procesos críticos de gestión de riesgo operativo, contar con respaldos periódicos de la información y disponer de un plan de continuidad y recuperación ante desastres
Seguridad	La aplicación debe integrarse con Entra ID para autenticación corporativa, implementar control de acceso basado en roles (RBAC), eliminar accesos locales y asegurar cifrado de la información en tránsito y en reposo
Monitoreo	La aplicación debe integrarse con log analytics, generando métricas, logs y alertas.
Extensibilidad	La aplicación debe soportar la incorporación de nuevos módulos, cambios metodológicos e integraciones futuras sin requerir rediseños estructurales.
Resiliencia	La aplicación debe manejar fallos de forma controlada y considerar mecanismos de reintento y recuperación.
Durabilidad	La aplicación debe garantizar la integridad, consistencia y retención de la información mediante el uso de una base de datos empresarial con controles de integridad referencial y políticas de respaldo

Mantenibilidad y Operación	La aplicación debe contar con un modelo formal de soporte, gestión de versiones, control de cambios y un ciclo de vida de desarrollo seguro
Continuidad Operativa	La aplicación debe contar con un plan de continuidad y recuperación ante desastres alineado a los lineamientos del banco.
Agilidad	La aplicación debe permitir la creación, configuración y despliegue automatizado de sus componentes mediante la plataforma Hefesto, cumpliendo las políticas, estándares y lineamientos de DevSecOps

Consecuencias

Positivas	*A tener en cuenta*
• Mayor alineación de la plataforma con la metodología de riesgo operativo del Banco. • Reducción de manualidades y reprocesos operativos. • Mejora en trazabilidad, control y calidad de la información. • Mayor flexibilidad para evolución regulatoria y del negocio. • Fortalecimiento del gobierno y la autonomía tecnológica del Banco.	• Incremento de la responsabilidad interna de operación, soporte y evolución. • Necesidad de inversión en robustecimiento arquitectónico y controles de seguridad. • Requiere madurez en el modelo operativo y de gobierno TI. • Riesgo inicial durante la transición desde Riskment Suite a EMMA. • Mayor demanda de capacidades técnicas internas.

Controles de seguridad de la información para tener en cuenta**

N°	Nombre	Comentarios	Aplica
1	Protocolo proyectos de software, automatización y nube Cuando el objetivo es la creación de nuevas aplicaciones Web, aplicaciones de escritorio, automatizaciones de procesos y creación de servicios de integración, ya sea en infraestructura On Premise, Cloud o Hibrida	4.1. Control de acceso lógico 4.2 Roles y perfiles 4.6.1. Controles de seguridad en la nube 4.8 Transferencia de archivos	SI
2	Protocolo proyectos y requerimientos para nuevas funcionalidades de una aplicación Cuando sea necesario adicionar nuevas características o capacidades a una aplicación para mejorar su rendimiento, utilidad, experiencia del usuario, mejoras en la seguridad, solucionar incidentes, entre otros. Las nuevas funcionalidades pueden ser nuevos módulos, nuevos cálculos, generación reportes, nuevas integraciones, etc.		NO
3	Proyectos y requerimientos para migración de datos Cuando sea necesario transferir datos de un sistema o plataforma a otro, con el objetivo de actualizar infraestructuras tecnológicas, cambiar a un sistema más robusto y eficiente, migrar servicios a la nube, entre otros		NO
4	Proyectos de Baja Complejidad Cuando el objetivo es la implementación o actualización de aplicaciones suministradas por un tercero que soportan procesos de apoyo para el Banco y cuya infraestructura es On-Premise. También aplica para la actualización por obsolescencia de la infraestructura que lo soporta.		NO

5	Proyectos digitales Este protocolo aplica para el desarrollo de proyectos digitales en canales, productos del banco y aquellos establecidos por el corporativo, incluido proyectos en los que se cuenta con apoyo de terceros expertos en metodologías ágiles.		NO

CONTROL CAMBIOS DEL ADR

Fecha	Tipo	Comentarios	Responsable ADR	Aprobador
2/03/2026	Creado	Versión inicial	Camila Diaz	CoE Arquitectura